

Identity and Access Management (IAM) Audit Report

Microsoft Entra ID – Privileged Access Review (Lab Audit)

1. Executive Summary

This report documents an Identity and Access Management (IAM) audit conducted within a Microsoft Entra ID tenant to evaluate privileged access controls, administrative role assignments, and governance limitations.

The audit assessed:

- Global Administrator exposure
- Emergency (break-glass) account configuration
- Role-based access control (RBAC) intent using security groups
- Governance and licensing constraints affecting group-based role assignment

Evidence is stored separately and referenced by Figure number. See Docs/Evidence_Index.md.

2. Audit Scope

In Scope

- Microsoft Entra ID tenant configuration and role assignments
- Privileged identities and Global Administrator exposure
- Security groups and membership (RBAC design intent)
- Evidence exports and documentation

Out of Scope

- Conditional Access policies
 - Privileged Identity Management (PIM)
 - Application permissions / Enterprise Apps permissions
 - Device compliance controls
-

3. Objectives

1. Identify users with Global Administrator privileges
 2. Validate a break-glass (emergency) administrative account
 3. Establish RBAC intent via security groups and memberships
 4. Test feasibility of group-based directory role assignment
 5. Document risks, limitations, and remediation recommendations
-

4. Environment Overview

- Platform: Microsoft Entra ID
- Tenant: Personal lab tenant (validated)
- License: Microsoft Entra ID Free
- Users: Admin, Developer, Helpdesk, Security Analyst + Break-glass admin
- Groups: Cloud-Admins, IT-Helpdesk

Evidence Reference

- Tenant validation: Figure 1
-

5. Methodology

The audit followed a structured review workflow:

1. Tenant scope validation
 2. User and privilege enumeration
 3. Break-glass account verification
 4. RBAC group design and membership baseline
 5. Role assignment capability testing
 6. Evidence export and documentation
-

6. Findings

Finding 1: Multiple Global Administrators Present

Description

The environment contained more than one Global Administrator assignment, increasing privileged access exposure.

Risk

Excessive privileged access increases risk of unauthorized configuration changes, credential compromise impact, and governance gaps.

Impact

High

Evidence Reference

- Global Admin assignments review: Figure 5
- Primary export evidence: Files/GlobalAdmin_Assignments.csv

Recommendation

- Minimize standing Global Administrator accounts
 - Reserve Global Admin usage for emergency or controlled admin workflows
 - Implement periodic access reviews and documented approvals
-

Finding 2: Break-Glass Account Configured

Description

A break-glass account was configured and assigned Global Administrator privileges for emergency administrative recovery.

Impact

Positive control observed

Evidence Reference

- Break-glass admin role assignment: Figure 4

Recommendation

- Secure break-glass credentials and document emergency access procedures

- Periodically test access and validate monitoring/alerts where applicable
-

Finding 3: RBAC Intent Implemented Using Security Groups

Description

Security groups were created to model role-based access (Cloud-Admins, IT-Helpdesk). Baseline memberships were established.

Impact

RBAC design intent documented

Evidence Reference

- Groups created: Figure 7
- Baseline group membership (before state): Figure 8
- Test users population: Figure 6

Recommendation

- Maintain group-based access design as the preferred enterprise pattern
 - Use functional naming conventions and document membership rules
-

Finding 4: Group-Based Directory Role Assignment Not Available (Licensing Constraint)

Description

Group-based assignment of directory roles (e.g., Global Administrator to Cloud-Admins) could not be enabled or executed in this tenant.

Root Cause

Microsoft Entra ID Free licensing does not expose the control required to assign directory roles to groups.

Impact

Medium (governance limitation)

Evidence Reference

- Limitation observed in Roles & administrators configuration: Figure 9

Risk

- Directory roles must be assigned directly to users, increasing administrative overhead and risk of privilege sprawl.

Recommendation

- Upgrade to Microsoft Entra ID P1/P2 to enable group-based directory role assignment and advanced identity governance capabilities (e.g., PIM)
 - Until then, apply compensating controls:
 - Manual access reviews
 - Strong change control for role assignment
 - Evidence retention (CSV exports + documented approvals)
-

7. Risk Summary

Area	Severity
Excess standing Global Admin exposure	High
Licensing constraint limiting group-based RBAC enforcement	Medium
Break-glass account presence	Low (positive control)
RBAC design intent via security groups	Low

8. Compensating Controls

Due to licensing constraints, the following controls are recommended:

- Scheduled access review cadence (e.g., monthly)
 - Documented approvals for role assignment changes
 - Role assignment exports retained as evidence
 - Least privilege enforcement for administrative roles
-

9. Conclusion

This IAM audit produced evidence-backed findings on privileged access exposure and governance constraints. While group-based directory role assignment could not be implemented due to licensing, the audit documented RBAC intent, privileged role state, and compensating control recommendations consistent with real-world IAM assessment practices.

10. Evidence Handling

Evidence artifacts referenced in this report are stored separately to preserve traceability:

- Screenshots: Evidence/Before/Screenshots/ and Evidence/After/Screenshots/
- Exports: Files/GlobalAdmin_Assignments.csv
- Evidence index: Docs/Evidence_Index.md